

CineList

Rapport Technique

Plateforme de Gestion de Watchlist Cinématographique

Date: 07 juin 2026

Table des matières

1. Introduction
2. Technologies utilisées
3. Architecture de l'application
4. Fonctionnalités détaillées
5. Sécurité
6. Conclusion

1. Introduction

CineList est une application web moderne destinée à la gestion personnelle de watchlist cinématographique. Elle permet aux utilisateurs d'organiser leur collection de films, de suivre leur progression de visionnage, de noter et commenter les films, et de rechercher facilement dans leur bibliothèque. L'application est entièrement multi-utilisateur avec authentification sécurisée.

Objectifs:

- Fournir une interface intuitive et élégante pour gérer une collection de films
- Implémenter une authentification sécurisée avec sessions et cookies persistants
- Permettre le stockage d'images d'affiche directement en base de données
- Offrir des fonctionnalités de recherche, filtrage et tri en temps réel
- Assurer l'isolation des données par utilisateur

2. Technologies utilisées

Backend

- **PHP 8.2+** : Langage côté serveur, orienté objet, prepared statements
- **PDO (PHP Data Objects)** : Abstraction pour accès sécurisé à la base de données
- **Sessions PHP** : Gestion d'authentification avec `session_start()`, `session_regenerate_id()`
- **Bcrypt** : Hachage sécurisé des mots de passe avec `cost=12`
- **Cookies HttpOnly** : Stockage sécurisé des tokens « Remember Me »

Base de données

- **MySQL/MariaDB** : Système de gestion de base de données relationnelle
- **4 tables principales** : users, films, remember_tokens
- **LONGBLOB** : Stockage des images d'affiche (max 3 Mo par film)
- **Contraintes de clé étrangère** : Garantissent l'intégrité référentielle
- **Encodage UTF-8** : Support complet de caractères internationaux

Frontend

- **HTML5** : Structure sémantique, formulaires accessibles
- **CSS3** : Grid, Flexbox, variables CSS, gradients, animations
- **JavaScript ES6+** : Fetch API, AJAX, gestion d'événements, DOM manipulation
- **Design responsive** : Mobile-first, breakpoints adaptés
- **Thème sombre cinématographique** : Palette de couleurs : #0c0c0f, #e8c96a, #c97b4b

3. Architecture de l'application

Structure fichiers

- **db.php** : Singleton PDO, fonction getPDO()
- **auth.php** : Middleware authentification, sessions, remember-me
- **index.php** : Page principale (protégée), affichage grille films
- **login.php** : Formulaire connexion avec email/username
- **register.php** : Formulaire inscription avec validation
- **logout.php** : Destruction session et cookie
- **actions.php** : API JSON, CRUD films, recherche, filtrage
- **poster.php** : Endpoint pour servir images depuis BLOB
- **app.js** : Logique cliente (AJAX, DOM, événements)
- **style.css** : Feuille de style complète, 16KB
- **cinelist.sql** : Script de création base + données démo

Flux de requête

1. Client envoie requête HTML ou AJAX
2. index.php / actions.php reçoit et valide
3. auth.php vérifie session/cookie, redirige si non-auth
4. db.php fournit PDO avec prepared statements
5. Requête SQL exécutée avec user_id filtrant
6. Réponse JSON ou HTML rendue
7. Frontend reçoit et met à jour DOM

4. Fonctionnalités détaillées

Gestion des films

- **Ajout** : Titre, réalisateur, année, genre, statut initial, affiche (JPG/PNG/WebP/GIF, max 3 Mo)
- **Modification** : Changement de statut, notation, commentaire
- **Suppression** : Avec confirmation
- **Affiche** : Stockée en LONGBLOB, servie via poster.php?id=X
- **Métadonnées** : Créée_at, updated_at timestamps

Suivi de visionnage

- **3 statuts** : À voir (■) | En cours (■) | Vu (✓)
- **Changement instantané** : Select dropdown, requête AJAX
- **Statistiques** : Comptage en temps réel (total, vus, à voir, moyenne note)

Notation et commentaires

- **Notation** : 1 à 5 étoiles (★), changement au hover
- **Commentaires** : Édition inline au clic
- **Stockage** : TEXT non limité en base

Recherche et filtrage

- **Recherche** : Temps réel sur titre/réalisateur (debounce 350ms)
- **Filtrage** : Par statut (buttons), visuel du filtre actif
- **Tri** : Par créée_at, titre A-Z, année, note
- **Combos** : Tous les filtres/recherches se combinent

5. Sécurité

Authentification

- **Mot de passe** : Hashé Bcrypt (cost=12), jamais stocké en clair
- **password_verify()** : Vérification sécurisée
- **Session regenerate_id** : Prévention fixation de session
- **Remember token** : Hash SHA-256 du token stocké, jamais le token brut
- **Cookie flags** : HttpOnly (JS ne peut lire), SameSite=Lax (CSRF)

Base de données

- **Prepared statements** : PDO bindValue() prévient SQL injection
- **Paramètres nommés** : :email, :id, :uid
- **Filtrage user_id** : Toutes les requêtes filtrent par session['user_id']
- **Erreurs** : PDOException capturées, jamais affichées à l'utilisateur

Frontend

- **htmlspecialchars()** : Échappement des données en HTML
- **JSON.stringify** : Pas d'eval() ou innerHTML avec données non filtrées
- **CSRF** : POST via AJAX seulement (tokens optionnels)
- **Validation client** : HTML5 + JS (validation serveur obligatoire aussi)

Téléchargement fichiers

- **Validation MIME** : mime_content_type() ou finfo
- **Limite taille** : 3 Mo max
- **Stockage BDD** : Pas de répertoire accessible publiquement
- **Endpoint poster.php** : Contrôle d'accès par user_id

6. Conclusion

CineList démontre l'implémentation d'une application web full-stack moderne, sécurisée et conviviale. Elle combine des technologies éprouvées (PHP, MySQL, JavaScript vanilla) avec des pratiques de sécurité robustes (prepared statements, Bcrypt, sessions régénérées, HttpOnly cookies). Le design cinématographique sombre et l'interface responsive offrent une expérience utilisateur agréable sur tous les appareils.

Améliorations futures possibles:

- **API REST** : Endpoints pour intégrations tierces
- **Pagination** : Grille infinie ou paginée
- **Import/Export** : CSV, JSON, iCal
- **Social** : Partage watchlist, comparaison avec amis
- **Notifications** : Email/push pour sorties cinéma
- **GraphQL** : Requêtes optimisées côté client
- **Admin panel** : Gestion utilisateurs, statistiques globales
- **Dark/Light mode** : Préférence utilisateur
- **PWA** : Installation et utilisation hors-ligne